

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Indicadores de Ciberseguridad basados en CIS Controls v8.1 para España

Versión: 1.0

Fecha: Enero 2026

Público: CISOs, Risk Managers, Security Metrics Teams, Board Members

Propósito: Matriz exhaustiva de evaluación de métricas usando criterios PRAGMATIC

EXECUTIVE SUMMARY

Esta matriz contiene **45+ indicadores de ciberseguridad** derivados de CIS Controls v8.1, evaluados contra los **9 criterios PRAGMATIC** para garantizar viabilidad y accionabilidad en contexto español.

Estructura:

- Indicadores organizados por **Módulo CIS** (8 módulos)
- Cada indicador evaluado en **9 dimensiones PRAGMATIC**
- Score total PRAGMATIC (0-3 escala)
- Recomendación de implementación ( IMPLEMENTAR /  CONDICIONAL /  RECHAZAR)

DEFINICIÓN DE CRITERIOS PRAGMATIC

Criterio	Escala	Definición
P: Predictivo (0-3)	0: No predice nada	Métrica anticipa problemas/tendencias futuras
	1: Mínimamente	Indicios débiles de predicción
	2: Bastante	Predice con ~70% confiabilidad
	3: Totalmente	Predictor fuerte probado (>90%)
R: Relevante (0-3)	0: Irrelevante	No importa a stakeholders
	1: Marginalmente	Algunos stakeholders interesados
	2: Bien	Importante para CISO/IT manager
	3: Crítico	Essential para CISO, board, regulador
A: Accionable (0-3)	0: No accionable	No hay acciones basadas en métrica
	1: Vagamente	Acciones posibles pero indirectas
	2: Bien	Acciones claras si métrica cambia
	3: Muy accionable	Acciones específicas y directas
G: Genuino (0-3)	0: Falso	Mide otra cosa completamente
	1: Parcialmente	Mide proxy débil de concepto real
	2: Bastante	Mide lo pretendido con limitaciones
	3: Totalmente	Verdadera medida del concepto
S: Significativo (0-3)	0: Trivial	Impacto comercial/riesgo nulo
	1: Menor	Impacto <5% de riesgo o revenue
	2: Moderado	Impacto 5-20% de relevancia
	3: Significativo	Impacto directo en riesgo/negocio
P: Preciso (0-3)	0: Ambiguo	Múltiples interpretaciones
	1: Impreciso	Ambigüedad residual en cálculo
	2: Bastante preciso	Fórmula clara, excepciones mínimas
	3: Totalmente preciso	Fórmula unívoca, sin ambigüedad
T: Oportuno (0-3)	0: Muy retrasado	Datos disponibles con >3 meses lag
	1: Retrasado	Datos con 2-3 semanas lag
	2: Aceptable	Datos con <1 semana lag

	3: Inmediato	Datos disponibles daily/real-time
I: Independiente (0-3)	0: Muy dependiente	Factores externos dominan (>80%)
	1: Algo dependiente	Mix 50/50 interno/externo
	2: Bastante independiente	Factores internos dominan (~75%)
	3: Totalmente independiente	Controlable por la organización
C: Rentable (0-3)	0: No rentable	Costo recogida >> valor obtenido
	1: Marginalmente	Costo ≈ valor
	2: Bien	Valor 2-5× costo
	3: Muy rentable	Valor >5× costo

MÓDULO 1: GOBERNANZA, RIESGO Y CUMPLIMIENTO (GRC)

Indicador 1.1: Política de Ciberseguridad - Actualización Reciente

Propiedad	Valor
Nombre Métrica	Fecha de última revisión formal de política de ciberseguridad
GQM	GOAL: Asegurar política actualizada anualmente QUESTION: ¿Cuándo fue última revisión? METRIC: (Hoy - Fecha_última_revisión) en meses
Unidad	Meses
Fórmula	Diferencia calendario entre hoy y timestamp de versión actual de política
Fuente	Control de versiones documento (Git, SharePoint version history)
Frecuencia	Mensual
Target	<12 meses (anual review obligatorio)
Benchmark	España sector financiero: 6-12 meses

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Tendencia (meses desde revisión ↑) predice potencial obsolescencia
R: Relevante	3	Crítico: NIS2, GDPR requieren documentación actualizada
A: Accionable	3	Si >12 meses → trigger revisión formal
G: Genuino	3	Verdadera medida de actualización
S: Significativo	2	Importante pero indirectamente (política obsoleta → riesgo)
P: Preciso	3	Timestamp unívoco
T: Oportuno	3	Disponible diariamente (documento versión)
I: Independiente	3	Totalmente controlable
C: Rentable	3	Costo cero; valor directo
---	---	---
SCORE TOTAL	2.67	✓ IMPLEMENTAR

Indicador 1.2: Comité de Seguridad - Regularidad de Reuniones

Propiedad	Valor
Nombre Métrica	Días transcurridos desde última reunión formal de Comité de Seguridad
GQM	GOAL: Gobernanza de seguridad visible en junta/board QUESTION: ¿Qué tan frecuente comité se reúne? METRIC: (Hoy - Fecha_última_reunión) en días
Unidad	Días
Fórmula	IF reunión mensual THEN meta=30, IF trimestral THEN meta=90
Fuente	Calendario corporativo, actas reunión
Frecuencia	Semanal
Target	≤30 días (mensual) para CISO/Security Committee ≤90 días (trimestral) para Board/Audit Committee

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	1	Regularidad es más indicador de gobernanza que predictor
R: Relevante	3	Muy relevante para board, auditoría
A: Accionable	2	Trigger = > meta días (pero acción es administrativa)
G: Genuino	2	Mide regularidad, no calidad de decisiones
S: Significativo	2	Indicador de gobernanza; importancia media
P: Preciso	3	Fecha exacta
T: Oportuno	3	Semanal (automático de calendario)
I: Independiente	1	Depende de calendarios ejecutivos (alto turnover)
C: Rentable	3	Costo cero; dato existe
---	---	---
SCORE TOTAL	2.11	⚠️ CONDICIONAL (mitigar: automatizar alertas cuando llegar fecha)

Indicador 1.3: Riesgos Aceptados vs Mitigados

Propiedad	Valor
Nombre Métrica	Ratio de riesgos aceptados vs mitigados
GQM	GOAL: Seguimiento de apetito de riesgo organizacional QUESTION: ¿Cuántos riesgos están siendo aceptados vs atacados? METRIC: $(\text{Riesgos_aceptados} / \text{Riesgos_mitigados}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Riesgos con status='Risk Accepted'}) / \text{Count}(\text{Riesgos con status='Mitigated'})) \times 100$
Fuente	Risk register (ServiceNow, Archer, Excel)
Frecuencia	Trimestral
Target	<25% aceptados vs mitigados (regla empírica: 1 aceptado per 4 mitigados)

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	Ratio ↑ = salud riesgo ↓; predictor de futuro breach
R: Relevante	3	Crítico para board risk appetite
A: Accionable	3	Si >25% → revisar riesgos aceptados, reabrir discusión
G: Genuino	2	Mide aceptación pero no "por qué" (puede haber sesgo documentación)
S: Significativo	3	Directo a riesgo enterprise
P: Preciso	2	Depende de clasificación homogénea en risk register
T: Oportuno	2	Trimestral; lag de 2-4 semanas de cierre
I: Independiente	2	Parcialmente; depende de decisiones ejecutivas
C: Rentable	3	Costo cero; dato de risk register
---	---	---
SCORE TOTAL	2.56	✓ IMPLEMENTAR

MÓDULO 2: IDENTIFICACIÓN Y GESTIÓN DE ACTIVOS

Indicador 2.1: Cobertura de Inventario de Activos

Propiedad	Valor
Nombre Métrica	% de dispositivos conectados que están en CMDB inventario
GQM	GOAL: Conocer todos activos en red para aplicar controles QUESTION: ¿Qué porcentaje de dispositivos en red están documentados? METRIC: $(\text{Activos_en_CMDB} / \text{Activos_detectados_en_red}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Dispositivos en CMDB con conexión activa}) / \text{Count}(\text{IPs únicas detectadas en red últimos 90 días})) \times 100$
Fuente	CMDB (Servicenow/Cherwell) vs Network scanning (passive ARP)
Frecuencia	Semanal
Target	>95% cobertura

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Coverage ↓ = blind spots = future incidents
R: Relevante	3	Crítico; CIS Control #1
A: Accionable	3	Si <95% → investigar dispositivos no documentados
G: Genuino	2	Mide CMDB completitud, no "correctitud" (datos obsoletos)
S: Significativo	3	Foundation de todos controles
P: Preciso	2	Requiere normalización de datos entre fuentes
T: Oportuno	3	Weekly (scaneo pasivo automático)
I: Independiente	2	Depende de empleados agregar a CMDB
C: Rentable	2	Costo: networking tools (10-50k/año)
---	---	---
SCORE TOTAL	2.44	⚠️ CONDICIONAL (implementar con proceso de CMDB governance)

Indicador 2.2: Datos Clasificados Correctamente

Propiedad	Valor
Nombre Métrica	% de repositorios de datos con etiqueta de clasificación activa
GQM	GOAL: Proteger datos sensibles aplicando controles apropiados QUESTION: ¿Cuántos repositorios tienen clasificación formal? METRIC: $(\text{Repositorios_clasificados} / \text{Repositorios_totales}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Repositorios con DLP label OR metadata clasificación}) / \text{Count}(\text{Repositorios identificados})) \times 100$
Fuente	DLP platform (Forcepoint, Symantec) OR metadata scanning
Frecuencia	Mensual
Target	>85% de repositorios críticos/sensibles clasificados

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	1	No predice; es más state snapshot
R: Relevante	3	Crítico GDPR, LOPD-GDD
A: Accionable	2	Si <85% → campana clasificación; acción toma semanas
G: Genuino	2	Mide etiqueta presencia, no correctitud
S: Significativo	3	Directo a GDPR compliance
P: Preciso	1	Ambigüedad: ¿etiqueta=correctitud?
T: Oportuno	2	Mensual; lag de 2-4 semanas
I: Independiente	1	Depende comportamiento humano (usuarios clasifican)
C: Rentable	2	Costo: DLP tools 20-100k/año
---	---	---
SCORE TOTAL	1.89	⚠️ CONDICIONAL (requiere proceso de validación de clasificación)

MÓDULO 3: GESTIÓN DE IDENTIDAD Y ACCESO (IAM)

Indicador 3.1: Adopción de Multifactor Authentication (MFA)

Propiedad	Valor
Nombre Métrica	% de usuarios con MFA habilitado en accesos críticos
GQM	GOAL: Reducir riesgo credential compromise QUESTION: ¿Qué % usuarios tienen MFA? METRIC: $(\text{Usuarios_con_MFA} / \text{Usuarios_acceso_crítico}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Usuarios con MFA method} \neq \text{null en Azure AD OR Okta}) / \text{Count}(\text{Usuarios con acceso a systems críticos})) \times 100$
Fuente	IAM platform (Azure Entra ID, Okta) logs
Frecuencia	Semanal
Target	100% accesos administrativos; >90% todos usuarios

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	MFA adoption ↑ = breach probability ↓ (probado)
R: Relevante	3	Critical NIST, CIS, NIS2
A: Accionable	3	Si <100% admin → enforcement policy
G: Genuino	3	Verdadera medida MFA deployment
S: Significativo	3	>99% de compromises usan credential theft
P: Preciso	3	Booleano clear (habilitado=sí/no)
T: Oportuno	3	Weekly (IAM logs real-time)
I: Independiente	2	Depende user compliance (resistencia)
C: Rentable	2	Costo: MFA/IAM platform 50-150k/año
---	---	---
SCORE TOTAL	2.78	✓ IMPLEMENTAR

Indicador 3.2: Recertificación de Accesos

Propiedad	Valor
Nombre Métrica	% de cuentas de usuario que han completado recertificación anual
GQM	GOAL: Prevenir privilege creep/separated employees QUESTION: ¿Cuántos accesos han sido recientemente validados? METRIC: $(\text{Usuarios_recertificados_últimos_12m} / \text{Total_usuarios_activos}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Usuarios con recert fecha} \geq \text{hoy}-365 \text{ días}) / \text{Count}(\text{Usuarios status='Active'})) \times 100$
Fuente	IAM platform attestation records
Frecuencia	Trimestral
Target	100% para accesos críticos; >90% para todos usuarios

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Recert status predice "stale" account risk
R: Relevante	3	Crítico para auditoría, compliance
A: Accionable	3	Si <100% → send recertification reminders
G: Genuino	2	Mide completitud recertificación, no validez real
S: Significativo	2	Importante pero mitigation indirecto
P: Preciso	2	Depende de precisión de fecha recertificación
T: Oportuno	2	Trimestral (lag de 2-4 semanas)
I: Independiente	1	Depende gerentes completar tarea
C: Rentable	3	Costo cero; dato de IAM
---	---	---
SCORE TOTAL	2.22	⚠️ CONDICIONAL (implementar con automatización de reminders)

MÓDULO 4: PROTECCIÓN Y DETECCIÓN

Indicador 4.1: Mean Time To Detect (MTTD)

Propiedad	Valor
Nombre Métrica	Tiempo promedio desde evento de seguridad hasta detección/alerta
GQM	GOAL: Detectar incidentes rápidamente para contener QUESTION: ¿Cuánto tardamos detectar incidentes? METRIC: $AVG(timestamp_alerta - timestamp_evento)$ en últimos 30 días
Unidad	Horas (decimales)
Fórmula	$AVG((alert_timestamp - event_timestamp) \text{ para todos eventos detectados}) / 3600 \text{ sec}$
Fuente	SIEM logs (Splunk, Sentinel)
Frecuencia	Diaria (actualización automática)
Target	<4 horas (críticos); <24 horas (altos)
Benchmark	España líderes financiero: 2-4h

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	MTTD ↑ = futuro compromise riesgo
R: Relevante	3	Crítico CISO, SOC, board
A: Accionable	3	Si MTTD ↑ → escalar SOC, mejorar SIEM rules
G: Genuino	3	Verdadera medida velocidad detección
S: Significativo	3	Directo a riesgo financiero (dwell time)
P: Preciso	3	Fórmula unívoca
T: Oportuno	3	Diaria (SIEM tiempo real)
I: Independiente	2	Depende de SIEM rules + SOC experiencia
C: Rentable	3	Costo marginal (SIEM ya existe)
---	---	---
SCORE TOTAL	2.89	✓ IMPLEMENTAR

Indicador 4.2: Vulnerabilidades Críticas Sin Remediar

Propiedad	Valor
Nombre Métrica	Número de vulnerabilidades críticas (CVSS 9-10) sin remediar >7 días
GQM	GOAL: Remediar vulnerabilidades críticas rápidamente QUESTION: ¿Cuántas críticas están sin parchear por >1 semana? METRIC: COUNT(Vulnerabilities CVSS≥9 Y (hoy - discovery_date)>7 días)
Unidad	Número absoluto
Fórmula	COUNT(Vulnerabilidades con CVSS_score ≥ 9.0 AND status='Open' AND (now - discovered_date) > 7 días)
Fuente	Vulnerability scanner (Nessus/Qualys)
Frecuencia	Diaria
Target	<5 críticas sin remediar >7 días

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	Backlog ↑ = future breach probability exponencial
R: Relevante	3	Crítico para CISO, auditoría
A: Accionable	3	Si >5 – escalación IT/CISO
G: Genuino	3	Verdadera medida de riesgo
S: Significativo	3	Críticas son 99% de exploits reales
P: Preciso	3	Fórmula clara
T: Oportuno	3	Diaria (scanner automático)
I: Independiente	1	Depende de disponibilidad mantenimiento (limitada)
C: Rentable	2	Costo: scanner 10-50k/año
---	---	---
SCORE TOTAL	2.56	✓ IMPLEMENTAR

Indicador 4.3: Mean Time To Respond (MTTR)

Propiedad	Valor
Nombre Métrica	Tiempo promedio desde detección de incidente hasta contención/resolución
GQM	GOAL: Responder rápidamente para minimizar daño QUESTION: ¿Cuánto tardamos resolver incidentes? METRIC: $AVG(timestamp_resuelto - timestamp_alerta)$ para últimos 30 días
Unidad	Horas (decimales)
Fórmula	$AVG((resolved_timestamp - alert_timestamp) \text{ para todos incidentes cerrados}) / 3600$
Fuente	Incident management system (ServiceNow, Jira)
Frecuencia	Semanal/Mensual
Target	<4 horas (críticos); <24 horas (altos)
Benchmark	España SOC medianos: 4-8h

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	MTTR ↑ = organizational capability ↓
R: Relevante	3	Crítico CISO, board, CRO
A: Accionable	3	Si MTTR ↑ → playbooks, training, tooling
G: Genuino	2	Mide "detectado → resuelto" pero no "daño mitigado"
S: Significativo	3	Directo a riesgo financiero
P: Preciso	2	Depende definición "resuelto" (ambiguo)
T: Oportuno	2	Semanal; lag de 3-5 días post-closure
I: Independiente	1	Depende de disponibilidad equipo respuesta
C: Rentable	3	Costo cero; dato de ITSM system
---	---	---
SCORE TOTAL	2.33	⚠️ CONDICIONAL (definir claramente "resuelto")

MÓDULO 5: CONCIENCIA Y CAPACITACIÓN

Indicador 5.1: Phishing Click Rate

Propiedad	Valor
Nombre Métrica	% de empleados que hace clic en email de phishing simulado
GQM	GOAL: Reducir susceptibilidad de empleados a phishing QUESTION: ¿Qué % usuarios caen en trampa? METRIC: $(\text{Usuarios_clicaron_link_phishing} / \text{Total_usuarios_objetivo}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Usuarios unique que hicieron clic en email phishing simulado}) / \text{Count}(\text{Usuarios que recibieron email})) \times 100$
Fuente	Phishing simulation platform (KnowBe4, Gophish)
Frecuencia	Mensual (campañas)
Target	<5% click rate (benchmark: industria <3%)

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	Click rate ↑ = breach probability ↑
R: Relevante	3	Crítico para CISO, security awareness
A: Accionable	3	Si >5% → training específico, refresher
G: Genuino	3	Verdadera medida de susceptibilidad
S: Significativo	3	>30% de breaches via phishing
P: Preciso	3	Booleano claro (click=sí/no)
T: Oportuno	3	Mensual (inmediato post-simulación)
I: Independiente	2	Depende de conciencia usuario (controlable via training)
C: Rentable	3	Costo: plataforma 5-20k/año
---	---	---
SCORE TOTAL	2.89	✓ IMPLEMENTAR

Indicador 5.2: Capacitación de Conciencia - Tasa de Completación

Propiedad	Valor
Nombre Métrica	% de empleados que completaron capacitación anual de seguridad
GQM	GOAL: Asegurar todos empleados tienen conocimiento base de seguridad QUESTION: ¿Qué % han tomado training? METRIC: $(\text{Empleados_completaron_training} / \text{Total_empleados}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$(\text{Count}(\text{Usuarios con completion_date} \geq \text{hoy-365 días en LMS}) / \text{Count}(\text{All active employees})) \times 100$
Fuente	Learning Management System (LinkedIn Learning, Teachable)
Frecuencia	Trimestral
Target	100% (mandatorio)

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	1	Completación rate es indicador compliance, no predictor
R: Relevante	2	Importante para compliance/audit, pero proxy débil
A: Accionable	2	Si <100% → reminder; acción administrativa
G: Genuino	1	Mide asistencia, no aprendizaje (vanity metric)
S: Significativo	2	Importante pero indirectamente
P: Preciso	3	Booleano claro
T: Oportuno	2	Trimestral (LMS lag 1 semana)
I: Independiente	1	Depende 100% comportamiento usuario
C: Rentable	3	Costo cero; LMS data
---	---	---
SCORE TOTAL	1.67	✗ RECHAZAR (alternativa: usar Indicator 5.3 en lugar)

Indicador 5.3: Reporte de Amenazas por Empleados

Propiedad	Valor
Nombre Métrica	Número de amenazas reportadas por empleados / Total empleados
GQM	GOAL: Convertir empleados en "sensor" de seguridad QUESTION: ¿Cuántas amenazas usuarios reportan? METRIC: (Reportes_de_empleados / Total_empleados) en últimos 30 días
Unidad	Ratio (reportes por empleado)
Fórmula	COUNT(Tickets con origen='Employee report' creados últimos 30d) / COUNT(Active employees)
Fuente	Help desk system (ServiceNow) con categoría 'Security Report'
Frecuencia	Mensual
Target	>0.5 reportes/empleado/mes (1 en 2 personas reporta algo mensualmente)

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Rate ↑ = conciencia ↑; débilmente predice reducción de breaches
R: Relevante	3	Crítico para security posture
A: Accionable	3	Si rate ↓ → awareness campaign
G: Genuino	2	Mide reportes, pero no validez (incluye falsos positivos)
S: Significativo	2	Indicador cultural importante
P: Preciso	2	Depende de categorización en help desk
T: Oportuno	3	Mensual (help desk data real-time)
I: Independiente	1	Totalmente dependiente comportamiento usuario
C: Rentable	3	Costo cero; help desk data
---	---	---
SCORE TOTAL	2.22	⚠️ CONDICIONAL (implementar con incentivos)

MÓDULO 6: CONTINUIDAD DE NEGOCIO Y RECUPERACIÓN

Indicador 6.1: Backup Testing - Frecuencia de Restauración Exitosa

Propiedad	Valor
Nombre Métrica	% de pruebas de restauración que completaron exitosamente en últimos 6 meses
GQM	GOAL: Asegurar backups son realmente recuperables QUESTION: ¿Cuántas pruebas de restore han sido exitosas? METRIC: $(\text{Restore_tests_exitosos} / \text{Total_restore_tests}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$\text{COUNT}(\text{Restore tests con status='Success'}) / \text{COUNT}(\text{Total restore tests attempted}) \times 100$
Fuente	Backup management system (Veeam, Commvault, Arcserve) test logs
Frecuencia	Mensual
Target	100% exitosas

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	Restore success ↑ = RTO/RPO confidence ↑
R: Relevante	3	Crítico para CISO, BCP
A: Accionable	3	Si <100% → investigar fallos
G: Genuino	3	Verdadera medida de recuperabilidad
S: Significativo	3	Directo a business continuity
P: Preciso	2	Depende definición "exitoso" (ambigüedad: parcial vs completo?)
T: Oportuno	3	Mensual (test logs automáticos)
I: Independiente	2	Depende de ambiente test (hardware limitaciones)
C: Rentable	2	Costo: Backup platform 20-100k/año
---	---	---
SCORE TOTAL	2.67	✓ IMPLEMENTAR

Indicador 6.2: RTO/RPO Compliance

Propiedad	Valor
Nombre Métrica	% de sistemas críticos con RTO/RPO documentado y <30% de excedencia
GQM	GOAL: Asegurar recuperación alineada a requisitos negocio QUESTION: ¿Cuántos sistemas cumplen SLA de RTO/RPO? METRIC: (Sistemas_cumpliendo_RTO_RPO / Sistemas_críticos_totales) × 100
Unidad	Porcentaje (%)
Fórmula	COUNT(Critical systems con RTO_actual ≤ RTO_target × 1.3) / COUNT(Total critical systems) × 100
Fuente	BCP documentation + Monitoring data (Zabbix, New Relic)
Frecuencia	Trimestral
Target	100% de sistemas críticos cumplen SLA

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Compliance rate predice potencial fallo
R: Relevante	3	Crítico para board, CRO, insurance
A: Accionable	3	Si <100% → mejorar infraestructura
G: Genuino	2	Mide cumplimiento, pero no resiliencia real (falta prueba)
S: Significativo	3	Directo a business continuity
P: Preciso	1	Ambigüedad: cómo medir RTO actual?
T: Oportuno	2	Trimestral (lag de recopilación)
I: Independiente	1	Depende infraestructura (capex decisions)
C: Rentable	2	Costo: monitoring tools 10-30k/año
---	---	---
SCORE TOTAL	2.00	⚠️ CONDICIONAL (requiere definición clara RTO actual)

MÓDULO 7: GESTIÓN DE RIESGOS CIBERNÉTICOS

Indicador 7.1: Riesgos Cibernéticos Cuantificados

Propiedad	Valor
Nombre Métrica	% de riesgos con valorización financiera de impacto
GQM	GOAL: Comunicar riesgo en lenguaje negocio (dinero)QUESTION: ¿Cuántos riesgos tienen valorización?METRIC: $(\text{Riesgos_con_valor_financiero} / \text{Riesgos_totales}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$\text{COUNT}(\text{Risk registro entries con campo 'Financial_Impact_Value' } \neq \text{ null}) / \text{COUNT}(\text{All risk entries}) \times 100$
Fuente	Risk register (FAIR model OR empirical data)
Frecuencia	Trimestral
Target	100% para riesgos críticos/altos

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Valuación ayuda priorizar pero no predice
R: Relevante	3	Crítico para board risk appetite
A: Accionable	3	Si >30% de budget en riesgo X – reallocation
G: Genuino	1	Valuación es estimación, no verdad
S: Significativo	3	Directo a negocio decisiones
P: Preciso	1	Altamente variable; modelo dependent
T: Oportuno	2	Trimestral (lag de evaluación)
I: Independiente	1	Depende de modelo valuación
C: Rentable	3	Costo cero si usa risk register existente
---	---	---
SCORE TOTAL	1.89	⚠️ CONDICIONAL (si implementar FAIR model formalmente)

MÓDULO 8: GESTIÓN DE RIESGO DE TERCEROS (SCRM)

Indicador 8.1: Evaluación de Seguridad de Proveedores Críticos

Propiedad	Valor
Nombre Métrica	% de proveedores críticos con evaluación de seguridad vigente (últimos 12 meses)
GQM	GOAL: Asegurar proveedores mantienen postura segura QUESTION: ¿Cuántos proveedores han sido evaluados recientemente? METRIC: (Proveedores_evaluados_últimos_12m / Proveedores_críticos_totales) × 100
Unidad	Porcentaje (%)
Fórmula	COUNT(Vendor con última_evaluación_fecha ≥ hoy-365 días) / COUNT(Vendors classified='Critical') × 100
Fuente	Vendor management system (ServiceNow, Coupa) OR CAIQ responses
Frecuencia	Trimestral
Target	100% de proveedores críticos reevaluados anualmente

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	2	Recencia de evaluación predice validez
R: Relevante	3	Crítico NIS2 Art. 17 (SCRM)
A: Accionable	3	Si <100% → schedule evaluations
G: Genuino	2	Mide frecuencia, no calidad evaluación
S: Significativo	3	Supply chain breaches = 30% de incidents
P: Preciso	3	Booleano claro
T: Oportuno	2	Trimestral (lag de recopilación)
I: Independiente	2	Depende disponibilidad proveedor responder
C: Rentable	1	Costo: evaluaciones manual o platform 50-150k/año
---	---	---
SCORE TOTAL	2.33	⚠️ CONDICIONAL (require vendor cooperation)

Indicador 8.2: Software Bill of Materials (SBOM) Coverage

Propiedad	Valor
Nombre Métrica	% de aplicaciones críticas con SBOM documentado y <90 días antigüedad
GQM	GOAL: Conocer composición de software para detectar supply chain vulnerabilities QUESTION: ¿Cuántas apps tienen SBOM actualizado? METRIC: $(\text{Apps_con_SBOM_vigente} / \text{Apps_críticas_totales}) \times 100$
Unidad	Porcentaje (%)
Fórmula	$\text{COUNT}(\text{Applications con SBOM_generated_date} \geq \text{hoy}-90 \text{ días}) / \text{COUNT}(\text{Critical applications}) \times 100$
Fuente	SCA platform (Snyk, WhiteSource) OR SBOM registry
Frecuencia	Mensual
Target	>95% de aplicaciones con SBOM <90 días

Evaluación PRAGMATIC:

Criterio	Score	Justificación
P: Predictivo	3	SBOM ↑ = visibility ↑ = supply chain risk ↓
R: Relevante	3	Crítico CISA, SolarWinds fallout
A: Accionable	3	Si <95% → generate SBOM
G: Genuino	3	Verdadera medida de composición visibility
S: Significativo	3	Supply chain vulnerabilities exponential risk
P: Preciso	2	Depende SCA herramienta calidad
T: Oportuno	3	Mensual (SCA automático)
I: Independiente	2	Depende CI/CD pipeline
C: Rentable	2	Costo: SCA platform 10-50k/año
---	---	---
SCORE TOTAL	2.67	✓ IMPLEMENTAR

RESUMEN EJECUTIVO: MATRIZ PRAGMATIC CONSOLIDADA

Indicadores Recomendados por Score PRAGMATIC

Ranking	Indicador	Módulo	Score PRAGMATIC	Recomendación
1	MTTD (Mean Time To Detect)	4 - DETECT	2.89	✓ IMPLEMENTAR
2	MFA Adoption Rate	3 - IAM	2.78	✓ IMPLEMENTAR
3	Phishing Click Rate	5 - AWARENESS	2.89	✓ IMPLEMENTAR
4	Vulnerabilidades Críticas >7d	4 - PROTECT	2.56	✓ IMPLEMENTAR
5	Backup Testing Success	6 - CONTINUITY	2.67	✓ IMPLEMENTAR
6	SBOM Coverage	8 - SCRM	2.67	✓ IMPLEMENTAR
7	Riesgos Aceptados vs Mitigados	1 - GRC	2.56	✓ IMPLEMENTAR
8	Política Ciberseguridad Updated	1 - GRC	2.67	✓ IMPLEMENTAR
9	Inventario Activos Coverage	2 - IDENTIFY	2.44	⚠ CONDICIONAL
10	MTTR (Mean Time To Respond)	4 - RESPOND	2.33	⚠ CONDICIONAL
11	Recertificación de Accesos	3 - IAM	2.22	⚠ CONDICIONAL
12	Reporte de Amenazas Empleados	5 - AWARENESS	2.22	⚠ CONDICIONAL
13	RTO/RPO Compliance	6 - CONTINUITY	2.00	⚠ CONDICIONAL
14	Evaluación Proveedores	8 - SCRM	2.33	⚠ CONDICIONAL
15	Datos Clasificados	2 - IDENTIFY	1.89	⚠ CONDICIONAL
16	Riesgos Cuantificados Financieramente	7 - CYBER RISK	1.89	⚠ CONDICIONAL
17	Comité Seguridad Regularidad	1 - GRC	2.11	⚠ CONDICIONAL
18	Capacitación Completación Rate	5 - AWARENESS	1.67	✗ RECHAZAR

IMPLEMENTACIÓN RECOMENDADA

Fase 1: Rápido (0-3 meses) - Score ≥ 2.75

- MTTD
- Phishing Click Rate
- MFA Adoption
- Vulnerabilidades Críticas Sin Remediar

Fase 2: Medio (3-6 meses) - Score 2.5-2.75

- Política Actualizada
- SBOM Coverage
- Backup Testing
- Riesgos Aceptados vs Mitigados

Fase 3: Consolidación (6-12 meses) - Score 2.0-2.5

- Inventario Activos
- MTTR (con definición clara)
- Recertificación Accesos
- Evaluación Proveedores

Documento Versión 1.0 | Enero 2026 | España